

PENETRATION TEST REPORT

Metasploitable 2 Lab Environment

Target: 192.168.56.102 | Tester: Danny | Date: June 7, 2026

Open Ports	Successful Attacks	Partial/Failed	Status
23	11	4	COMPLETE

1. Engagement Scope

Field	Details
Target IP	192.168.56.102
Target Name	Metasploitable 2 (metasploitable.localdomain)
Tester	Danny
Test Type	Black-box Penetration Test (Lab Environment)
Network	Host-only — 192.168.56.0/24 (hacking_lab)
Date	June 7, 2026
Tools Used	Nmap, Metasploit, Hydra, sqlmap, manual browser attacks
Status	COMPLETE — 15 attacks attempted, 11 successful, 2 partial, 2 failed

2. Reconnaissance — Nmap Scan Results

Command: nmap -sV -O -A 192.168.56.102 — Revealed 23 open TCP ports across a wide range of services.

Port	Service	Version	Risk	Notes
21/tcp	FTP	vsftpd 2.3.4	Critical	Known backdoor CVE-2011-2523. Anonymous login enabled.
22/tcp	SSH	OpenSSH 4.7p1	Medium	Outdated, weak 1024-bit DSA keys.
23/tcp	Telnet	Linux telnetd	High	Cleartext protocol. Default creds msfadmin/msfadmin.
25/tcp	SMTP	Postfix smtpd	Medium	SSLv2 enabled, expired certificate, VRFY allowed.
53/tcp	DNS	ISC BIND 9.4.2	Medium	Outdated BIND, zone transfer may be possible.
80/tcp	HTTP	Apache 2.2.8	High	Hosts DVWA, Mutillidae — SQLi, XSS, RFI, LFI.
111/tcp	RPC	rpcbind 2	Medium	Exposes NFS mount info.
139/tcp	SMB	Samba 3.0.20	Critical	CVE-2007-2447 usermap_script. No message signing.
445/tcp	SMB	Samba 3.0.20-Debian	Critical	Same as above. Guest access enabled.
512/tcp	rexec	netkit-rsh rexecd	High	Legacy r-service, no encryption.
513/tcp	rlogin	OpenBSD rlogind	High	Legacy r-service, exploitable with .rhosts.
514/tcp	rsh	Netkit rshd	High	Remote shell, no auth if .rhosts configured.
1099/tcp	Java RMI	GNU Classpath gmreregistry	High	Java deserialization exploit possible.
1524/tcp	Bindshell	Root shell	Critical	OPEN ROOT SHELL — no auth required.
2049/tcp	NFS	RPC #100003	High	May expose shares without auth.
3306/tcp	MySQL	MySQL 5.0.51a	Critical	Root account with no password.
5432/tcp	PostgreSQL	PostgreSQL 8.3.0	High	Default creds postgres/postgres.
5900/tcp	VNC	Protocol 3.3	High	Older protocol, weak auth.

6000/tcp	X11	X11	Medium	Display server exposed.
6667/tcp	IRC	UnrealIRCd	Critical	Backdoor CVE-2010-2075.
8180/tcp	Tomcat	Apache Tomcat 5.5	High	Manager app with default creds tomcat/tomcat.

3. Exploitation Log

All 15 attacks are documented below including successes, partials, and failures with root cause analysis.

#	Target	Method	Result	Notes
1	vsftpd 2.3.4 (port 21)	exploit/unix/ftp/vsftpd_234_backdoor_espand_netcat	2000-ESSA ✓	Root shell uid=0(root). Backdoor spawned on port 4444. Reverse shell failed c
2	Samba 3.0.20 (port 139/445)	exploit/multi/samba/usermap_script_espand_netcat	2000-ESSA ✓	Root shell uid=0(root). CVE-2007-2447 command injection via SMB username
3	UnrealIRCd (port 6667)	exploit/unix/irc/unreal_ircd_328_backdoor	2000-ESSA ✓	Target confirmed vulnerable. Backdoor triggered but no stable session created
4	Bindshell (port 1524)	nc 192.168.56.102 1524 — no exploit needed	2000-ESSA ✓	Root shell uid=0(root). Pre-planted root shell — direct netcat connection with z
5	MySQL 5.0.51a (port 3306)	mysql -u root -h 192.168.56.102 -u root -h 192.168.56.102	2000-ESSA ✓	Full DB access as root with no password. 7 databases exposed. DVWA creds
6	Telnet (port 23)	telnet → msfadmin/msfadmin	2000-ESSA ✓	Root shell uid=0(root). Default credentials accepted instantly. msfadmin has fu
7	Java RMI (port 1099)	exploit/multi/misc/java_rmi_server_espand_meterpreter	2000-ESSA ✓	Intermediate payload type first (needed Java payload). RMI class loader could
8	Apache Tomcat 5.5 (port 8080)	exploit/multi/http/tomcat_mgr_upload_espand_netcat	2000-ESSA ✓	Upload file to Tomcat. Upload file to Tomcat. Upload file to Tomcat. Upload file to Tomcat.
9	DVWA SQL Injection (port 80)	Manual: 1' OR '1'='1 + UNION SELECT * FROM users	2000-ESSA ✓	Full user, password, email, username, password via browser. OR injection returned all 5 users. UNION
10	DVWA Reflected XSS (port 80)	Manual: <script>alert('Hacked by Danny')</script>	2000-ESSA ✓	JavaScript executed in browser. Input reflected without sanitization. In real att
11	DVWA Stored XSS (port 80)	Manual: <script>alert('Stored XSS')</script>	2000-ESSA ✓	Script persisted to database. Fires for every visitor automatically — no interact
12	DVWA Command Injection (port 80)	Manual: 127.0.0.1 whoami / cat /etc/passwd	2000-ESSA ✓	OS command execution as www-data (uid=33). Pipe not filtered at Low securi
13	DVWA Local File Inclusion (port 80)	Manual: ?page=../../../../../../../../etc/passwd	2000-ESSA ✓	Full /etc/passwd read via URL. Initial 4x ../ failed — needed 6x ../ to reach root
14	PostgreSQL 8.3.1 (port 5432)	auxiliary/scanner/postgres/postgres_login	2000-ESSA ✓	postgres confirmed. Modern psql client SSL-incompatible — Metasp
15	SSH Brute Force (port 22)	Hydra -l msfadmin -P rockyou. 192.168.56.102	2000-ESSA ✓	192.168.56.102 incompatible with Metasploitable's ancient SSH MACs (hmac-md5

4. Lessons Learned

Compiled at end of session — 15 attacks attempted across network services and web applications.

What Went Well	What Was Challenging	Key Takeaways
• Nmap recon mapped full attack surface in one session • vsftpd and Samba exploits worked first try • Bindshell and MySQL needed zero exploitation • Telnet default creds + sudo = instant root • All 5 DVWA attacks succeeded • PostgreSQL cracked via Metasploit when postgres file path issue required recovery before lab start • Documenting failures produced a realistic report	• Subnet mismatch broke reverse shells through NAT • UnrealIRCd backdoor triggered but no stable session • Java RMI blocked by routing — needs same subnet • Tomcat WAR deployed but session failed • Modern Kali tools incompatible with ancient products	• Always set LHOST correctly — use bind payloads in NAT/sessions • Dangerous vulns need no exploits: open shells, no-pas • Document failures — they show environment constraints • Unsalted MD5 = plaintext • When one tool fails, try another • Try multiple injection separators (; &&) • Recon quality determines exploitation quality

5. Remediation Recommendations

The following mitigations would apply in a real-world environment:

Severity	Recommendation
Critical	Remove or firewall the bindshell on port 1524 — this is an open root shell with no auth.
Critical	Patch vsftpd to a non-backdoored version and disable anonymous FTP login.
Critical	Upgrade Samba — CVE-2007-2447 allows unauthenticated RCE via username field.
Critical	Set a strong root password on MySQL and restrict remote root access.
High	Disable Telnet, rsh, rlogin, rexec — replace with SSH using key-based auth.
High	Set strong unique passwords on PostgreSQL, VNC, and Tomcat Manager.
High	Upgrade all services to current supported versions.
High	Implement input validation and output encoding to prevent SQLi, XSS, and CMDi.
Medium	Disable SSLv2 on all services and replace expired TLS certificates.
Medium	Restrict NFS exports and require authentication.
Medium	Place the server behind a firewall — only expose necessary ports.
Medium	Use salted password hashing (bcrypt/argon2) — MD5 is trivially cracked.